

Board Briefing Note



To: The Board of Directors, MediPay Sdn Bhd

From: UniKL L02 -B03 Group R

Re: Cloud Migration — Compliance & Data-Privacy Recommendation

Date: 9 September 2026

Recommendation: Adopt the proposed cloud provider, subject to five conditions being met before go-live.

We do not recommend rejecting this provider. The infrastructure is capable and, where we independently tested it, performed as claimed. The gap is contractual and configurational not technical and is closable before migration.

1. The three findings that matter most

- a. **Breach notification is not fast enough to protect you, on paper.** The provider commits only to notifying MediPay "without undue delay", no fixed number of hours. Malaysian law gives MediPay 72 hours to notify the Commissioner once it knows of a breach. If the provider's own confirmation takes several days, MediPay's clock may already be gone. This is the largest single exposure identified.
- b. **Your patients' data may leave the region you chose, by default.** Some backup services replicate data across regions automatically unless explicitly disabled. Left unaddressed, this risks an unauthorised cross-border transfer under the amended PDPA a failure MediPay would own, not the provider.
- c. **MediPay cannot independently verify the provider's claims.** The contract offers self-reported certificates on request, but no right to independent audit. A certificate is weaker evidence than a verified control, and leaves MediPay accountable for claims it cannot check.

2. The honest picture

Where we tested the provider's controls directly (encryption, access restrictions, network isolation, deletion schedules) they held up. Two tests also surfaced narrower gaps where encryption is on but not confirmed to use a MediPay-controlled key and activity logging exists but was only verified via a workaround, so the production-grade audit trail isn't yet independently confirmed.

3. Consequence & exposure

A missed 72-hour notification is a statutory breach in its own right, regardless of the underlying incident. An unauthorised cross-border transfer carries separate PDPA enforcement exposure. Inability to verify controls weakens MediPay's standing with its PCI DSS assessor, its clinics and the Commissioner, if tested. We raise these not to discourage migration (compliant providers are the market norm) but a reassuring-only briefing would not be an honest one.

4. What we are asking the Board to approve

Sign-off on migration on condition the following are secured in writing before any patient or card data moves:

No	Condition	Owner
1	Fixed numeric breach-notification timeframe from the provider	Legal & Contracts
2	Contractual/technical controls preventing unannounced cross-region replication	Cloud Infrastructure
3	Independent audit right or documented acceptance of ISO 27001/SOC 2 as interim assurance	Legal & Compliance
4	Enforced use of a MediPay-controlled encryption key	Cloud Infrastructure
5	Confirmation that production-grade audit logging is enabled, not the lab equivalent used in this assessment	Cloud Infrastructure

We recommend the Board withhold final sign-off on migration until all five are confirmed.